



ACTIONS ON CYBER

— PRACTICAL GUIDANCE. REAL PROTECTION. —
READY TODAY. SECURE TOMORROW.

NIST CSF ALIGNED

ASSET AND DATA MANAGEMENT POLICY

NIST CSF Alignment: Identify | Protect

Defines how technology assets and organisational data are identified, owned, classified, handled and reviewed.

Document type: Policy template | Version: 1.0

Audience: Small and medium-sized organisations

Review frequency: Annual, or after a major system, data, supplier or process change

ACTIONS ON CYBER

Practical Guidance. Real Protection. Ready Today. Secure Tomorrow.

Asset and Data Management Policy

Template status: standalone starter policy for the Actions on Cyber Field Manual.

Disclaimer

This template is a starting point only. It is not legal advice and should be adapted to the organisation, sector, operating model, data sensitivity, contractual duties and regulatory obligations.

Document control

Field	Suggested wording
Policy owner	[Insert role, for example Managing Director, Operations Director, Head of IT, Data Owner or Cyber Lead]
Approved by	[Insert approving body, for example Board, Trustees or Senior Leadership Team]
Version	1.0
Effective date	[Insert date]
Next review date	[Insert date]
NIST CSF alignment	Identify and Protect - asset management, business environment, data classification, data handling and control expectations

Contents

1. Purpose
 2. Scope
 3. Asset and data management principles
 4. NIST CSF alignment
 5. Policy statements
 6. Roles and responsibilities
 7. Asset and data registers
 8. Data classification and handling
 9. Evidence and assurance
 10. Review and continual improvement
- Appendix A. Asset and data management checklist
- Appendix B. Suggested register fields

1. Purpose

The purpose of this policy is to define how the organisation identifies, records, owns, classifies, protects, reviews and disposes of technology assets and organisational data. It supports cyber risk management by ensuring that the organisation knows what it has, where important information is held, who owns it and how it should be protected.

This policy provides a practical baseline for small and medium-sized organisations. It should be supported by asset registers, data asset registers, supplier records, access control procedures, backup arrangements and incident response plans.

2. Scope

This policy applies to all information assets, business data, user devices, servers, cloud services, SaaS platforms, networks, applications, removable media, backups, supplier-hosted services and paper records that are used to create, access, store, process, transmit or dispose of organisational information.

It applies to employees, contractors, temporary workers, suppliers and any other party who has access to organisational systems, data or services.

3. Asset and data management principles

- Important systems, data sets and suppliers should have named owners.
- Assets and data should be recorded at a level of detail that supports risk management, incident response and recovery.
- Data should be classified and handled according to sensitivity, business value and potential harm if lost or disclosed.
- Access to assets and data should be granted only where there is a legitimate business need.
- Asset and data records should be reviewed regularly and updated when changes occur.
- Data should be retained only for as long as required for business, legal, regulatory or contractual reasons.
- Assets and data must be disposed of securely when they are no longer required.

4. NIST CSF alignment

This policy primarily supports the NIST Cybersecurity Framework functions of Identify and Protect. It also supports Govern, Detect, Respond and Recover by making critical assets, data owners and dependencies visible.

NIST CSF Function	How this policy supports it
Govern	Supports accountability by assigning owners for assets, data and related control expectations.
Identify	Requires technology assets, data sets, systems, suppliers and dependencies to be understood and recorded.
Protect	Connects data sensitivity and asset importance to access, handling, storage, encryption, backup and disposal controls.
Detect	Helps define what systems and data need logging, monitoring and vulnerability review.
Respond	Supports incident triage by identifying affected assets, data owners, suppliers and business impact.
Recover	Supports recovery planning by identifying critical systems, data and restoration priorities.

5. Policy statements

The following policy statements define the minimum asset and data management expectations for the organisation.

5.1 Asset inventory

The organisation must maintain an inventory of important technology assets, including user devices, servers, cloud services, SaaS platforms, business applications, network components and supplier-hosted services.

5.2 Asset ownership

Each critical system, important application, data set and supplier-hosted service must have a named owner who is accountable for its use, protection, access, risk and recovery expectations.

5.3 Data asset inventory

Important data sets must be recorded, including their owner, purpose, location, sensitivity, retention requirement, sharing arrangements and whether they are processed by suppliers.

5.4 Data classification

Data must be classified according to sensitivity and business impact. Classification should guide storage, sharing, access, encryption, retention and disposal requirements.

5.5 Approved storage locations

Organisational data must be stored only in approved locations such as managed cloud services, approved SaaS platforms, managed file stores or approved business systems.

5.6 Access to data and assets

Access must be granted based on business need, approved by an appropriate owner, reviewed periodically and removed when no longer required.

5.7 Supplier-hosted data

Where suppliers store, process or access organisational data, supplier ownership, data location, access arrangements, security expectations and incident notification routes must be understood.

5.8 Changes to assets and data flows

Major changes to systems, data flows, suppliers, integrations or storage locations must be assessed for cyber risk before implementation.

5.9 Secure disposal

Assets and data must be securely wiped, destroyed, archived or transferred when no longer required, in line with retention and disposal requirements.

5.10 Review and accuracy

Asset and data records must be reviewed at least annually and when material changes occur, such as new suppliers, systems, offices, integrations, data sets or business processes.

6. Roles and responsibilities

Role	Responsibilities
Board, trustees or owners	Approve expectations for asset and data management, support investment decisions and review material risks involving critical systems or sensitive data.
Senior accountable owner	Ensure that asset and data management is owned, reviewed and connected to cyber risk management and business continuity.
Policy owner	Maintain this policy, coordinate reviews and ensure related templates remain fit for purpose.
System and service owners	Maintain accurate records for systems and services, approve access, understand dependencies and support recovery planning.
Data owners	Classify data, approve sharing, define retention needs and ensure data is handled according to sensitivity.
IT, security or cyber lead	Maintain or support asset records, advise on controls, coordinate technical risk assessment and support secure disposal.
Supplier owners	Record supplier-hosted systems and data, ensure due diligence is completed and escalate supplier security concerns.
All users	Use approved systems, protect data, avoid unauthorised storage or sharing and report lost assets, data issues or suspected incidents promptly.

7. Asset and data registers

The organisation should maintain practical registers that help answer three questions: what do we have, who owns it and how important is it? Small organisations may use a single spreadsheet, provided it is reviewed and controlled.

Register	Minimum purpose
IT asset register	Records important devices, servers, applications, cloud services, network components and business systems.
Data asset register	Records important data sets, owners, classification, location, supplier processing and retention expectations.
SaaS register	Records cloud applications, owners, users, data stored, access model, MFA status and supplier contact details.
Critical systems register	Identifies systems that are essential for operations, customer service, legal obligations or recovery.

8. Data classification and handling

Data classification should be simple enough for staff to understand. The example model below can be tailored to the organisation.

Classification	Description	Example handling expectation
Public	Information approved for public release.	May be shared externally once approved. Check that it is accurate and current.
Internal	Business information intended for normal internal use.	Store in approved business systems. Share with staff and trusted parties with a business need.
Confidential	Sensitive business, customer, supplier, employee or commercial information.	Restrict access, use approved sharing methods, consider encryption and avoid public AI or personal accounts.
Restricted	Highly sensitive information where unauthorised disclosure could cause serious harm.	Limit to named users, use strong access controls, record sharing decisions and obtain senior approval where required.

Minimum handling rules

Area	Minimum expectation
Storage	Store organisational data only in approved systems and locations. Avoid personal email, personal cloud storage and unmanaged devices.
Sharing	Share data only with people or suppliers who have a legitimate business need and an approved method of access.
Encryption	Use encryption where data is sensitive, mobile, externally shared or stored on portable devices.
Backups	Important data must be backed up according to business impact and recovery requirements.
Retention	Keep data only for as long as required for business, legal, regulatory or contractual reasons.
Disposal	Delete, wipe, shred or destroy data and assets securely when they are no longer required.

9. Evidence and assurance

The organisation should maintain proportionate evidence that assets and data are being managed. Evidence should be useful, current and easy to review.

Evidence item	Purpose
Asset register	Shows that important assets and systems are recorded and owned.
Data asset register	Shows where important data is held, how sensitive it is and who owns it.
Access review records	Shows that access to systems and data is periodically checked.
Supplier security records	Shows that supplier-hosted systems and data processing are understood.
Backup test evidence	Shows that important data can be restored.
Disposal records	Shows that hardware and data are securely retired when no longer required.

10. Review and continual improvement

This policy should be reviewed at least annually and after any significant security incident, major business change, technology change, supplier change, audit finding or change in legal or regulatory expectations.

Asset and data registers should be updated when new systems, suppliers, integrations, data sets, devices or business processes are introduced. Lessons from incidents, recovery tests, supplier reviews and control testing should be used to improve asset and data management practices.

Practical implementation note

For a small organisation, asset and data management does not need to be complicated. Start with a simple list of your most important systems, data, suppliers and owners. The goal is to make risk, access and recovery decisions easier.

Appendix A. Asset and data management checklist

Use this checklist to review whether the minimum arrangements are in place.

Check	Yes / No / Notes
Important systems and applications are recorded in an asset register.	
Critical systems and data sets have named owners.	
SaaS and cloud services used by the organisation are recorded.	
Sensitive data sets are classified and handled appropriately.	
Supplier-hosted systems and data are recorded and owned.	
Approved storage locations are understood and communicated.	
Access to important systems and data is reviewed periodically.	
Important data is backed up and restore tests are recorded.	
Hardware and data disposal is controlled and evidenced.	
Registers are reviewed at least annually and after major changes.	

Appendix B. Suggested register fields

The following fields can be used to build simple asset and data registers. They can be combined into one spreadsheet for smaller organisations.

IT asset register fields

Field	Purpose
Asset ID	Unique identifier for the asset or system.
Asset name	Name of the device, application, service or platform.
Asset type	Laptop, server, SaaS, cloud service, network device, application or supplier-hosted service.
Owner	Named person or role accountable for the asset.
Business purpose	What the asset is used for and why it matters.
Location	Physical, cloud or supplier location where relevant.
Criticality	Low, medium, high or critical based on business impact.
Users / access model	Who uses it and how access is managed.
Support status	Supported, unsupported, end-of-life date or supplier support details.
Backup / recovery need	Whether the asset or data requires backup and recovery planning.

Data asset register fields

Field	Purpose
Data set name	Name or description of the important data set.
Data owner	Named person or role accountable for the data.
Classification	Public, internal, confidential or restricted.
Location	System, folder, cloud service, supplier platform or archive location.
Supplier processing	Whether a supplier stores, processes or accesses the data.
Retention period	How long the data should be kept.
Sharing restrictions	Any limits on internal, external or supplier sharing.
Recovery priority	How important the data is for recovery after disruption.

Document end

Tailor this policy before use. Replace bracketed fields, align ownership to your operating model and link this policy to your asset register, data register, access control policy, supplier security process and incident response plan.